

Marco Integrativo GQM + PRAGMATIC para Indicadores VAST Nacionales

1. Introducción

Este documento define un **marco integrativo** que combina la metodología Goal–Question–Metric (GQM) con los criterios PRAGMATIC para evaluar y diseñar indicadores derivados del enfoque VAST (modelado de amenazas visual, ágil y sencillo) a nivel nacional en España.

El objetivo es asegurar:

- Trazabilidad clara desde los **objetivos estratégicos nacionales** hasta las **preguntas** que formular a organizaciones y los **datos técnicos** que se recogen.
- Evaluación sistemática de cada métrica con los criterios PRAGMATIC: Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable.

2. Resumen de la metodología GQM

GQM estructura la medición en tres niveles:

1. Goal (Objetivo): qué se desea lograr y para qué.
2. Question (Pregunta): qué debemos preguntar/observar para saber si avanzamos hacia el objetivo.
3. Metric (Métrica): qué datos específicos se recopilan para responder a la pregunta.

Aplicado a un contexto nacional de ciberseguridad, los **objetivos** se vinculan a políticas públicas, planes nacionales y marcos regulatorios (NIS2, DORA, ENS, etc.), las **preguntas** se formulan a nivel de programa y organización, y las **métricas** se basan en datos operativos de los sistemas y procesos de las entidades.

3. Resumen de los criterios PRAGMATIC

Los criterios PRAGMATIC permiten evaluar la calidad de una métrica:

- P – Predictiva: ¿Ayuda a anticipar tendencias o problemas futuros?
- R – Relevante: ¿Está claramente relacionada con objetivos importantes?
- A – Accionable: ¿Sugiere acciones específicas cuando varía?
- G – Genuina: ¿Refleja la realidad sin manipulación fácil?
- M – Significativa (Meaningful): ¿Es comprensible y valiosa para las partes interesadas?
- P – Precisa: ¿Tiene suficiente exactitud para su uso?
- O – Oportuna (Timely): ¿Se puede obtener con la frecuencia necesaria?
- I – Independiente: ¿No se ve distorsionada por incentivos perversos o dependencias fuertes?
- C – Rentable (Cost-effective): ¿Compensa el coste de obtenerla y mantenerla?

En este marco, cada criterio se valora en una escala de 1 a 5 (muy bajo a muy alto), y se puede calcular una puntuación PRAGMATIC global por métrica.

4. Principales objetivos nacionales (Goal) inspirados en VAST

A partir del informe VAST nacional, sintetizamos los objetivos clave:

4. G1 – Mejorar la cobertura del modelado de amenazas en servicios esenciales y sistemas críticos.
5. G2 – Reducir la exposición a vulnerabilidades explotadas activamente en sistemas críticos.
6. G3 – Disminuir tiempos de detección, contención y recuperación de incidentes significativos a nivel país.
7. G4 – Aumentar la cuantificación del riesgo cibernético en términos económicos y su integración en decisiones de negocio y reguladoras.
8. G5 – Fortalecer la seguridad en la cadena de suministro y terceros críticos.
9. G6 – Impulsar el talento, la cultura de ciberseguridad y la colaboración sectorial y nacional.

Cada objetivo se despliega en un conjunto de preguntas (Q) y métricas (M) concretas.

5. Estructura GQM aplicada a indicadores VAST

A continuación se presentan tablas GQM para los principales objetivos, de forma resumida.

5.1. G1 – Cobertura de modelado de amenazas

Goal (G1): Asegurar que las organizaciones que prestan servicios esenciales o gestionan infraestructuras críticas cuentan con modelos de amenazas actualizados para la mayoría de sus sistemas críticos, integrados en su ciclo de vida de desarrollo y operación.

Código	Question (Pregunta)	Metric (Métrica)
G1.Q1	¿Qué proporción de sistemas críticos dispone de un modelo de amenazas formal?	G1.M1 – % de sistemas críticos con modelo de amenazas vigente.
G1.Q2	¿Con qué frecuencia se revisan y actualizan los modelos de amenazas?	G1.M2 – Frecuencia media (en meses) de revisión de modelos por sistema crítico.
G1.Q3	¿Se integra el modelado de amenazas en el SDLC/CI-CD?	G1.M3 – % de proyectos que incluyen modelado de amenazas en su pipeline de desarrollo/despliegue.
G1.Q4	¿Quién participa en el modelado y cómo se comunican sus resultados?	G1.M4 – Índice de participación multidisciplinar (número de roles implicados por sesión).

5.2. G2 – Vulnerabilidades explotadas activamente

Goal (G2): Reducir el volumen y la antigüedad de vulnerabilidades explotadas activamente en sistemas críticos.

Código	Question (Pregunta)	Metric (Métrica)
G2.Q1	¿Qué porcentaje de vulnerabilidades explotadas activamente está sin remediar?	G2.M1 – % de vulnerabilidades explotadas activamente abiertas en sistemas críticos.
G2.Q2	¿Cuál es la antigüedad de esas vulnerabilidades?	G2.M2 – % de vulnerabilidades explotadas activamente con más de 12 meses desde su publicación.
G2.Q3	¿Cuánto tiempo se tarda en corregir vulnerabilidades críticas?	G2.M3 – Tiempo medio de remediación de vulnerabilidades críticas (días).

5.3. G3 – Tiempos de detección, contención y recuperación

Goal (G3): Minimizar los tiempos de detección, contención y recuperación de incidentes significativos a nivel país.

Código	Question (Pregunta)	Metric (Métrica)
G3.Q1	¿Cuánto tiempo transcurre desde la intrusión hasta la detección?	G3.M1 – MTTD (tiempo medio de detección) de incidentes significativos (horas/días).
G3.Q2	¿Cuánto tiempo se tarda en contener incidentes significativos?	G3.M2 – MTTC (tiempo medio de contención) (horas/días).
G3.Q3	¿Cuánto tiempo se requiere para restaurar servicios críticos?	G3.M3 – MTTR (tiempo medio de recuperación) en servicios esenciales (horas/días).

5.4. G4 – Riesgo económico y decisiones

Goal (G4): Aumentar el uso de cuantificación económica del riesgo cibernético para informar decisiones de inversión y regulación.

Código	Question (Pregunta)	Metric (Métrica)
G4.Q1	¿Cuántas organizaciones cuantifican el riesgo en términos de pérdidas?	G4.M1 – % de organizaciones que utilizan modelos económicos (VaR, pérdidas esperadas, etc.).
G4.Q2	¿Con qué frecuencia reportan estos datos al Consejo o regulador?	G4.M2 – Frecuencia media de reporting de métricas económicas de riesgo.
G4.Q3	¿En qué medida las decisiones de inversión se basan en estos modelos?	G4.M3 – % de decisiones de inversión en ciber que hacen referencia explícita a modelos de riesgo.

5.5. G5 – Cadena de suministro y terceros

Goal (G5): Reforzar la gestión de ciber riesgos en proveedores y terceros críticos.

Código	Question (Pregunta)	Metric (Métrica)
G5.Q1	¿Qué porcentaje de proveedores críticos se evalúa con criterios de ciber?	G5.M1 – % de proveedores críticos con evaluación de ciber riesgos actualizada.
G5.Q2	¿Con qué frecuencia se revisan y actualizan estas evaluaciones?	G5.M2 – Frecuencia media de revisión de riesgos de terceros (meses).
G5.Q3	¿Cuántos incidentes significativos tienen origen en la cadena de suministro?	G5.M3 – % de incidentes significativos atribuibles a terceros / cadena de suministro.

5.6. G6 – Talento, cultura y colaboración

Goal (G6): Incrementar la disponibilidad de talento en ciberseguridad, la cultura de seguridad y la colaboración sectorial y nacional.

Código	Question (Pregunta)	Metric (Métrica)
G6.Q1	¿Qué nivel de recursos internos de ciberseguridad tienen las organizaciones?	G6.M1 – Índice de suficiencia de recursos (basado en autoevaluación estandarizada).
G6.Q2	¿Qué dificultades tienen para cubrir vacantes de ciberseguridad?	G6.M2 – % de organizaciones que reportan dificultades graves para cubrir vacantes.
G6.Q3	¿Qué cobertura tienen los programas de concienciación?	G6.M3 – % de empleados cubiertos por programas estructurados de concienciación anual.
G6.Q4	¿En qué medida participan en iniciativas de colaboración?	G6.M4 – % de organizaciones que participan en foros/CSIRTs sectoriales o nacionales.

6. Integración QQM + PRAGMATIC

Para cada métrica (Mx) definida en el esquema QQM, se le asigna una ficha PRAGMATIC con los siguientes campos:

- Código de la métrica (por ejemplo, G1.M1).
- Descripción.
- Fuente de datos y periodicidad.
- Escala y unidad de medida.
- Valoración PRAGMATIC (1-5) para cada criterio.
- Comentarios y riesgos de interpretación.

6.1. Ejemplo de ficha

Métrica G1.M1 – % de sistemas críticos con modelo de amenazas vigente

- Objetivo asociado (G): G1 – Cobertura de modelado de amenazas.
- Pregunta (Q): G1.Q1 – ¿Qué proporción de sistemas críticos dispone de un modelo de amenazas formal?
- Definición: $(\text{Nº de sistemas críticos con modelo de amenazas actualizado en el último año} / \text{Nº total de sistemas críticos}) \times 100$.
- Fuente: Inventario de activos y registros de modelado de amenazas de la organización.
- Periodicidad: Anual (idealmente semestral en sectores de alta criticidad).
- PRAGMATIC (1–5) – ver documento específico de Matriz PRAGMATIC.

Este patrón se repetirá para todas las métricas definidas.

7. Gobernanza del marco QM+PRAGMATIC

- Nivel nacional: definición de objetivos (G) y selección de preguntas agregadas (Q) a acordar entre autoridades competentes (CNC, CCN-CERT, INCIBE, reguladores sectoriales) y representantes de industria.
- Nivel organizativo: adaptación de preguntas (Q) y especificación de métricas (M) concretas según su contexto (sector, tamaño, criticidad).
- Nivel técnico: implementación en herramientas de gestión (GRC, ITSM, SIEM, plataformas de modelado de amenazas, etc.) para automatizar la recogida de datos.

8. Ciclo de revisión y mejora

10. Definir objetivos nacionales y métricas iniciales.
11. Pilotar el marco con un conjunto representativo de organizaciones.
12. Evaluar la calidad de las métricas usando PRAGMATIC.
13. Ajustar definiciones, fuentes y periodicidades.
14. Integrar resultados en dashboards nacionales y sectoriales.
15. Revisar anualmente objetivos, preguntas y métricas.

Este marco QM+PRAGMATIC pretende evitar el síndrome del “dashboard bonito pero inútil”: cada gráfica debe servir a un objetivo claro y activar decisiones concretas.